

CLOUD COMPUTING THREATS AND COUNTERMEASURES

Cloud Computing Concepts

Cloud Computing

An on-demand delivery of IT capabilities, in which IT infrastructure and applications are provided to subscribers as metered services over networks. Examples of cloud solutions include Google Cloud Platform, Amazon Web Services (AWS), Microsoft Azure, and IBM Cloud.

Characteristics of Cloud Computing

Here are the characteristics of cloud computing that attract many businesses today to adopt cloud technology.

- On-demand self-service
- Distributed storage
- Rapid elasticity
- Automated management
- Broad network access
- Resource pooling
- Measured service
- Virtualization technology

Limitations of Cloud Computing

- Limited control and flexibility of organizations
- Proneness to outages and other technical issues
- Security, privacy, and compliance issues
- Contracts and lock-ins
- Dependence on network connections
- Potential vulnerability to attacks as every component is online
- Difficulty in migrating from one service provider to another

Types of Cloud Computing Services

Cloud services are divided broadly into the following categories:

- **Infrastructure-as-a-Service (IaaS):** This cloud computing service enables subscribers to use on-demand fundamental IT resources, such as computing power, virtualization, data storage, and network. This service provides virtual machines and other abstracted hardware and operating systems (OSs), which may be controlled through a service application programming interface (API).
- **Platform-as-a-Service (PaaS):** This type of cloud computing service allows for the development of applications and services. This offers development tools, configuration management, and deployment platforms on-demand, which can be used by subscribers to develop custom applications (e.g., Google App Engine, Salesforce, Microsoft Azure).
- **Software-as-a-Service (SaaS):** This cloud computing service offers application software to subscribers on demand over the Internet. The provider charges for the service on a pay-per-use basis, by subscription, by advertising, or by sharing among multiple users.
- **Identity-as-a-Service (IDaaS):** This cloud computing service offers authentication services to the subscribed enterprises and is managed by a third-party vendor to provide identity and access management services. It provides services such as Single-Sign-On (SSO), Multi-Factor-Authentication (MFA), Identity Governance and Administration (IGA), access management, and intelligence collection.
- **Security-as-a-Service (SECaaS):** This cloud computing model integrates security services into corporate infrastructure in a cost-effective way. It is developed based on SaaS and does not require any physical hardware or equipment.

- **Container-as-a-Service (CaaS):** This cloud computing model provides containers and clusters as a service to its subscribers. It provides services such as virtualization of container engines, management of containers, applications, and clusters through a web portal or an API.
- **Function-as-a-Service (FaaS):** This cloud computing service provides a platform for developing, running, and managing application functionalities without the complexity of building and maintaining necessary infrastructure (serverless architecture). This model is mostly used while developing applications for microservices.

Cloud Deployment Models

Cloud deployment model selection is based on enterprise requirements. The five (5) standard cloud deployment models are:

- **Public Cloud:** In this model, the provider makes services such as applications, servers, and data storage available to the public over the Internet. Public cloud services may be free or based on a pay-per-usage model.
- **Private Cloud:** A private cloud, also known as the internal or corporate cloud, is a cloud infrastructure operated by a single organization and implemented within a corporate firewall.
- **Community Cloud:** A multi-tenant infrastructure shared among organizations from a specific community with common computing concerns, such as security, regulatory compliance, performance requirements, and jurisdiction.
- **Hybrid Cloud:** A cloud environment comprised of two or more clouds (private, public, or community) that remain unique entities but are bound together to offer the benefits of multiple deployment models.
- **Multi Cloud:** A dynamic heterogeneous environment that combines workloads across multiple cloud vendors that are managed via one proprietary interface to achieve long-term business goals. The multi-cloud uses multiple computing and storage services from different cloud vendors.

NIST Cloud Deployment Reference Architecture

Displays the primary actors, activities, and functions in cloud computing. The five (5) significant actors are as follows:

- **Cloud Consumer:** A person or organization that maintains a business relationship with the cloud service providers (CSPs) and utilizes the cloud computing services.
- **Cloud Provider:** A person or organization that acquires and manages the computing infrastructure intended for providing services (directly or via a cloud broker) to interested parties via network access.
- **Cloud Carrier:** Acts as an intermediary that provides connectivity and transport services between CSPs and cloud consumers. The cloud carrier provides access to consumers via a network, telecommunication, or other access devices.
- **Cloud Auditor:** A party that performs an independent examination of cloud service controls to express an opinion thereon. Audits verify adherence to standards through a review of objective evidence.
- **Cloud Broker:** The integration of cloud services is becoming too complicated for cloud consumers to manage. Thus, a cloud consumer may request cloud services from a cloud broker, rather than directly contacting a CSP.

Cloud Container Technology

Container Technology

An emerging container-based virtualization service. It helps developers and IT teams in developing, running, and managing containerized applications by using the API of the service provider or a web portal interface. Containers and clusters can be deployed in on-premises data centers or in the cloud.

Container

A package of an application/software including all its dependencies, such as libraries and configuration files, binaries, and other resources that run independently from other processes in the cloud environment. All these resource files are delivered as a unit to solve compatibility issues when applications are moved between cloud environments.

These containers are provided to the subscribers in the form of a Container-as-a-Service (CaaS). A CaaS service includes the virtualization and management of containers through orchestrators. Using these services, subscribers can develop rich, scalable containerized applications through the cloud or on-site data centers. It inherits features of both IaaS and PaaS.

Popular container services include Amazon AWS EC2, Google Kubernetes Engine (GKE), Docker, etc.

Features:

The implementation of containers offers many benefits, making them an attractive technology to various industries.

- **Portability and Consistency:** An application or software developed in a container includes all the resources required to perform. This portability helps clients or end-users run an application on various platforms and private or public cloud environments.
- **Security:** Owing to the independent nature of containers, security risks are reduced. If an application is attacked or compromised, its infections do not extend across the remaining containers.
- **High Efficiency and Cost Effectiveness:** Containers can run with fewer resources compared to virtual machines (VMs) because they do not need independent operating systems. Additionally, containers need a few megabytes of memory to run, enabling users to run multiple containers on a single server.
- **Scalability**
Containers are scalable and enable subscribers, or users, to integrate more similar containers under the same cluster to increase their size. The smart scaling technology enables users to run only the intended container and put unwanted containers at rest, making it cost-effective.
- **Robustness**
Containers can be generated, deployed, and destroyed in seconds because they do not require operating systems. This feature allows a quick development process, increased operational speed, and the launch of new software versions within the specified time.

Container Technology Architecture

The container technology has a five-tier architecture and undergoes a three-phase lifecycle:

- **Tier-1:** Developer Machines – image creation, testing, and accreditation
- **Tier-2:** Testing and Accreditation Systems – verification and validation of image contents, signing images, and sending them to the registries

- **Tier-3:** Registries – storing images and disseminating images to the orchestrators based on requests
- **Tier-4:** Orchestrators – transforming images into containers and deploying containers to hosts
- **Tier-5:** Hosts – operating and managing containers as instructed by the orchestrator

Container Security Challenges

Organizations are widely adopting container-based platforms owing to their features (e.g., flexibility, continuous application delivery, efficient deployment). However, the rapid growth and propagation of container technology has resulted in many security challenges. Discussed below are some of the challenges regarding container security:

- **Inflow of Vulnerable Source Code:** Containers constitute an open-source platform used by developers to regularly update, store, and use images in a repository, resulting in an enormous uncontrolled code that may include vulnerabilities, which can compromise security.
- **Large Attack Surface:** The host OS consists of many containers, applications, VMs, and databases in the cloud or on-premises. A large attack surface implies a large number of vulnerabilities and an increased difficulty in detecting them.
- **Lack of Visibility:** A container engine runs the container, interfaces with the Linux kernel, and creates another layer of abstraction camouflaging the actions of the containers and making it difficult to track the activities of specific containers or users.
- **Compromising Secrets:** Containers require sensitive information, such as API keys, usernames, or passwords, for accessing any services. Attackers who illicitly gain access to this sensitive information can compromise security.
- **DevOps Speed:** Containers can be executed promptly and, after execution, are stopped and removed. This fugitiveness helps attackers launch attacks and hide themselves without installing any malicious code.
- **Noisy Neighboring Containers:** A container may consume and exhaust all available system resources, which directly affects the operation of other neighboring containers, creating a denial-of-service (DoS) attack.
- **Container Breakout to the Host:** Containers that run as root may break the containment and gain access to the host OS through privilege escalation.
- **Network-based Attacks:** Attackers may exploit failed containers having active raw sockets and outbound network connections to launch various network-based attacks.
- **Bypassing Isolation:** Attackers, after compromising the security of a container, may escalate privileges to gain access to other containers or the host itself.
- **Ecosystem Complexity:** Containers are built, deployed, and managed using multiple vendors and sources. This makes it complex to secure and update the individual components because they originate from different repositories.

Virtual Machines, Docker, Microservices, Kubernetes

Virtual Machines

An essential technology that powers cloud computing. It provides the ability to run multiple OS on a single physical system and share the underlying resources, such as servers, storage devices, or networks. Virtualization allows organizations to cut IT costs while enhancing the productivity, utilization, and flexibility of their existing computer hardware.

Docker

An open-source technology used for developing, packaging, and running applications. All Docker dependencies are in the form of containers to ensure that applications can run in a seamless environment. The benefit of Docker is that when an application is packaged along with its dependencies into a Docker container, it can run in any environment.

Microservices

Monolithic applications are broken down into cloud-hosted sub-applications, called microservices, that work together, each performing a unique task. Microservices divide and distribute the application workload, providing stable, seamless, and scalable services by interacting with each other.

Kubernetes

Kubernetes, also known as K8s, is an open-source, portable, and extensible orchestration platform developed by Google for managing containerized applications and microservices. Containers provide an efficient way for packaging and running applications. In a real-time production environment, containers must be managed efficiently to bring downtime to zero.

Cloud Computing Threats, Tools, and Countermeasures

Cloud Computing Attacks

The following are various attack methods performed on the cloud computing environment.

Side-Channel Attacks or Cross-Guest VM Breaches

Attackers can compromise the cloud by placing a malicious virtual machine near a target cloud server and then launching a side-channel attack. The attacker runs the VM on the same physical host as the target VM and takes advantage of the shared physical resources (processor cache).

Then, he launches side-channel attacks (timing attack, data remanence, acoustic cryptanalysis, power monitoring attack, and differential fault analysis) to extract cryptographic keys/plain text secrets to steal the victim's credentials.

Wrapping Attack

This is performed during the translation of the SOAP message in the TLS layer, where attackers duplicate the body of the message and send it to the server as a legitimate user. The request first reaches the web server, then a SOAP message containing structural information is generated and exchanged with the browser during the passing of the message.

Before the message passing occurs, the browser needs to sign the XML document and canonicalize it. The attacker duplicates the message and sends it to the server as legitimate. The server verifies it through the signature (also duplicated) and validates its integrity. As a result, the adversary can intrude into the cloud and run malicious code to interrupt normal cloud functions.

Man-in-the-Cloud (MITC) Attack

This is an advanced version of MITM attacks. In MITM attacks, an attacker intercepts and manipulates communication between two parties, while MITC attacks are carried out by abusing cloud file synchronization services (e.g., Google Drive, DropBox). Attackers exploit synchronization tokens used for authentication in the cloud that cannot distinguish between malicious from normal traffic.

Cloud Hopper Attack

This is triggered at managed service providers (MSPs) and their customers. Once the attack is successfully implemented, attackers can gain remote access to the intellectual property and critical information of the target MSP and its global users/customers. Attackers use spear-phishing emails with custom malware to compromise users or cloud service firms.

Cloud Cryptojacking

This is the unauthorized use of the victim's computer to stealthily mine digital currency. When victims visit these pages, the crypto-miner runs automatically in their browser using JavaScript-based scripts (e.g., CoinHive, Cryptoloot).

Attackers may hide scripts through encoding, redirection, or obfuscation. These attacks can severely impact websites, endpoints, and entire cloud infrastructures.

Cloudborne Attack

A vulnerability in a bare-metal cloud server enables attackers to implant malicious backdoors in its firmware. The backdoor can persist even if the server is reassigned to new clients using it as IaaS. If firmware re-flash is improperly implemented during reclamation, the backdoor remains active and travels across servers.

Cloud Computing Tools and Countermeasures

Cloud Security Tools**Qualys Cloud Platform**

An end-to-end IT security solution offering continuous global assessment of security and compliance posture across all IT assets. It provides continuous visibility with real-time data analysis and threat response.

The platform performs active vulnerability checks (e.g., ICMP timestamp requests) and visualizes results via **AssetView**.

Cloud Attack Countermeasures

The following are various countermeasures for securing a cloud environment.

Side-Channel Attack Countermeasures

- Implement a virtual firewall in the cloud server back-end to prevent attackers from placing malicious VMs
- Implement random encryption and decryption (RSA, 3DES, AES)
- Lock down OS images and application instances to prevent compromise
- Monitor for repeated access attempts to local memory or shared hardware cache using local process monitoring
- Code OS components and applications to access shared resources (e.g., memory cache) predictably to prevent timing and behavioral data leaks

Wrapping Attack Countermeasures

- Use XML schema validation to detect SOAP message manipulation
- Apply authenticated encryption in the XML encryption specification

MITC Attack Countermeasures

- Use email security gateways to detect social engineering leading to MITCs
- Enforce strict token expiration policies
- Use antivirus tools capable of detecting and removing malware
- Deploy a Cloud Access Security Broker (CASB) to monitor traffic anomalies
- Monitor employee activity for signs of token abuse
- Encrypt cloud data and store encryption keys separately
- Implement two-factor authentication (2FA)

Cloud Hopper Attack Countermeasures

- Implement multi-factor authentication to protect credentials.
- Establish strong coordination between customers and CSPs for incident response.
- Ensure users comply with cloud service policies and follow security guidelines.

Cloud Cryptojacking Countermeasures

- Enforce strong password policies.
- Maintain three different copies of critical data (two on-site, one off-site).
- Patch web servers and devices regularly.
- Use encrypted SSH key pairs instead of passwords.
- Implement CoinBlocker URL and IP blacklist/blackholing in firewalls.
- Monitor web pages' DOM and JavaScript for malicious activities.
- Use up-to-date antivirus, anti-malware, and ad-blocking tools.
- Deploy browser extensions that detect and stop miner scripts.
- Use endpoint security management for rogue applications.
- Audit all third-party website components regularly.

Cloudborne Attack Countermeasures

- CSPs should keep all firmware versions up to date.
- Sanitize server firmware before reassigning systems to new customers.

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.